# Maemo Compliance — ISO 27001 & ISO 22301 Support Guide

**Document title:** How Maemo Compliance Supports ISO/IEC 27001 and ISO 22301
**Product:** Maemo Compliance
**Publisher:** Codist (Pty) Ltd
**Version:** 1.0
**Date:** July 2026
**Classification:** Client-facing — for evaluation, implementation planning, and audit preparation
**Companion document:** Maemo Product Specification v1.0

---

## Document control

| Version | Date | Author | Summary of changes |
|---|---|---|---|
| 1.0 | July 2026 | Codist Product Team | Initial ISO 27001 and ISO 22301 support guide |

---

## 1. Purpose of this document

This guide explains **how Maemo Compliance helps organisations implement, operate, and demonstrate** requirements arising from:

- **ISO/IEC 27001:2022** — Information Security Management Systems (ISMS)
- **ISO 22301:2019** — Business Continuity Management Systems (BCMS)

It is written for:

- Information security managers and BCMS coordinators evaluating software
- Compliance consultants scoping an ISMS/BCMS implementation
- Internal auditors preparing for certification or surveillance audits
- Procurement teams assessing fit against stated requirements

### Important disclaimer

**Maemo Compliance is software that supports management system processes. It does not, by itself, confer ISO 27001 or ISO 22301 certification.**

Certification requires:

- Organisational leadership, policy, and resources
- Competent people and defined processes beyond software
- Technical and physical controls implemented in your environment
- Internal audits and management review conducted by your organisation
- An accredited certification body conducting an independent audit

This document uses the terms **Supported**, **Partially supported**, and **Not supported** to describe how Maemo features map to standard requirements. **Partially supported** means Maemo provides tooling that assists the process, but the organisation must define content, operate adjacent controls, or use complementary systems.

---

## 2. Executive summary

| Standard | Overall Maemo fit | Summary |
|---|---|---|
| **ISO 27001:2022** | **Strong operational support** | Maemo directly supports ISMS documentation, risk treatment records, CAPA, internal audit, and POPIA-aligned privacy operations — core PDCA cycle activities. Annex A control operation relies on your technical stack; Maemo records and evidences management-system responses. |
| **ISO 22301:2019** | **Partial — process support** | Maemo supports BCMS **documentation, risk register, corrective action after disruptions/exercises, and audit** through existing modules. Dedicated BCM features (BIA tool, RTO/RPO registers, exercise scheduler, crisis comms) are **not yet built in**. Organisations can run a BCMS on Maemo today using document and NCR workflows; a dedicated ISO 22301 module is planned. |

### Recommended deployment patterns

| Pattern | When to use |
|---|---|
| **ISMS on Maemo** | SME to mid-market organisations certifying or maintaining ISO 27001; POPIA co-compliance required |
| **BCMS on Maemo (interim)** | Organisations building ISO 22301 using Maemo for policies, plans, risks, and CAPA while BIA/exercise tracking uses spreadsheets or a future Maemo release |
| **ISMS + BCMS combined** | Single tenant with ISO 27001 and ISO 22301 selected; integrated SHEQ/audit template; shared risk register with Information Security and Operational categories |
| **Maemo + specialist tools** | Large enterprises needing dedicated BCM software (BIA, crisis management) alongside Maemo for document control and audit evidence |

---

## 3. ISO/IEC 27001:2022 — How Maemo helps

### 3.1 What ISO 27001 requires (brief)

ISO 27001 specifies requirements for establishing, implementing, maintaining, and continually improving an ISMS. The structure follows **Plan-Do-Check-Act (PDCA)**:

| Clause | Theme |
|---|---|
| 4 | Context of the organisation |
| 5 | Leadership |
| 6 | Planning (risks, opportunities, objectives) |
| 7 | Support (resources, competence, documented information) |
| 8 | Operation (risk assessment, treatment, operational planning) |
| 9 | Performance evaluation (monitoring, internal audit, management review) |
| 10 | Improvement (nonconformity, corrective action) |

**Annex A** lists 93 information security controls in four themes (Organisational, People, Physical, Technological). Maemo does not auto-implement technical controls (firewalls, encryption, IAM) — it helps you **govern, document, assess, audit, and improve** them.

### 3.2 Maemo onboarding for ISO 27001

When **ISO 27001** is selected during signup or company setup, Maemo automatically:

1. Adds document categories: **Information Security Policy**, **Information Security Procedure**, **Information Security Record**
2. Seeds an **ISO 27001:2022 ISMS Audit** template with clause-themed questions (Context, Leadership, Planning, Support, Operation, Performance, Improvement)
3. Enables **Information Security** as a risk category in the risk register
4. Includes ISO 27001 in tenant `TargetStandardsJson` for reporting and configuration context

If ISO 27001 is selected together with other standards, an **Integrated SHEQ Management System Audit** template is also seeded, covering documentation, training, compliance, safety, environmental, incident management, and risk management themes.

### 3.3 Clause-by-clause support matrix (ISO 27001:2022)

| Clause | Requirement (summary) | Maemo support | Modules / features |
|---|---|---|---|
| **4.1** | Understand organisation and context | **Partially supported** | Store context analysis as controlled documents; no dedicated context register |
| **4.2** | Interested parties | **Partially supported** | Document stakeholder analysis in ISMS documentation |
| **4.3** | ISMS scope | **Supported** | Scope statement as approved controlled document with version history |
| **4.4** | ISMS | **Partially supported** | Platform hosts ISMS records; ISMS design is organisational |
| **5.1** | Leadership commitment | **Partially supported** | Policy documents with approval workflow evidence |
| **5.2** | Policy | **Supported** | Information Security Policy category; approval workflow; review dates |
| **5.3** | Roles and responsibilities | **Partially supported** | Document owners, approvers, NCR owners, risk owners; tenant roles (Admin, User, Consultant) |
| **6.1** | Actions to address risks and opportunities | **Supported** | Risk register with inherent/residual scoring; Information Security category |
| **6.1.2** | Information security risk assessment | **Supported** | Risk register; link risks to NCRs; review dates |
| **6.1.3** | Risk treatment | **Partially supported** | Existing controls (text), corrective actions via NCR; no SOA (Statement of Applicability) builder |

| | | | |
|---|---|---|---|
| **6.2** | Security objectives | **Partially supported** | Objectives documented and tracked as controlled documents; no dedicated objectives KPI module |
| **6.3** | Planning of changes | **Partially supported** | Change-controlled documents via approval workflow |
| **7.1** | Resources | **Not supported** | HR/finance systems |
| **7.2** | Competence | **Partially supported** | Training & competence procedure template (ISO 9001 pack, adaptable for ISMS) |
| **7.3** | Awareness | **Partially supported** | Distribute approved policies via document module; evidence of acknowledgement via records |
| **7.4** | Communication | **Partially supported** | Email notifications; no mass communication/campaign module |
| **7.5** | Documented information | **Supported** | Full document control: create, review, approve, version, archive, integrity hash |
| **8.1** | Operational planning and control | **Partially supported** | Procedures as controlled documents; operational records uploaded and classified |
| **8.2** | Risk assessment | **Supported** | Risk register — identify, analyse, evaluate (5×5 scoring) |
| **8.3** | Risk treatment | **Supported** | Mitigation via documented controls; CAPA via NCR; risk status lifecycle |
| **9.1** | Monitoring and measurement | **Partially supported** | Dashboard summary; review dates; no KRI/KPI engine |
| **9.2** | Internal audit | **Supported** | Audit templates, runs, evidence, findings, NCR from findings |
| **9.3** | Management review | **Partially supported** | Management review procedure template; inputs/outputs stored as documents and records |
| **10.1** | Nonconformity and corrective action | **Supported** | NCR module with root cause, corrective action, effectiveness verification |
| **10.2** | Continual improvement | **Supported** | NCR closure loop; document revision cycle; audit finding remediation |

### 3.4 Annex A control themes — practical Maemo mapping

Annex A contains 93 controls. Maemo does not provide one checkbox per control. Instead, the table below groups controls by theme and explains how Maemo typically supports **management system evidence** for each group.

| Annex A theme | Examples | Maemo role | Typical gap |
|---|---|---|---|
| **Organisational (37 controls)** | Policies, roles, asset inventory, supplier | **Policies/procedures** in Documents; **incidents** as NCRs; | Asset inventory CMDB, automated supplier risk scoring, SOA matrix |

| | | | |
|---|---|---|---|
| | relationships, incident management | **supplier** docs as controlled records; **audit** evidence | |
| **People (8 controls)** | Screening, terms of employment, awareness training | **Training procedure** template; training **records** as documents | HR integration, automated training LMS |
| **Physical (14 controls)** | Secure areas, equipment, clear desk | **Procedures** documented; **audit** verifies compliance | Physical access systems, CCTV — outside Maemo |
| **Technological (34 controls)** | Access control, cryptography, logging, secure development | **Policies** and **risk register** (Information Security); **NCR** for control failures; **POPIA trail** for data access | IAM, SIEM, vulnerability scanners — implemented in IT stack, evidenced in Maemo |

### 3.5 POPIA synergy (South African organisations)

Organisations implementing ISO 27001 in South Africa typically align with **POPIA**. Maemo provides:

| POPIA need | Maemo feature |
|---|---|
| Identify records containing personal information | PII classification fields on documents |
| Retention limitation | PII retention period (months); records retention scheduling |
| Security safeguards (administrative) | Document access control via authenticated portal; audit logging |
| Accountability — demonstrate access | **POPIA access trail report** (admin) with CSV export |
| Data breach response documentation | POPIA data breach notification template |

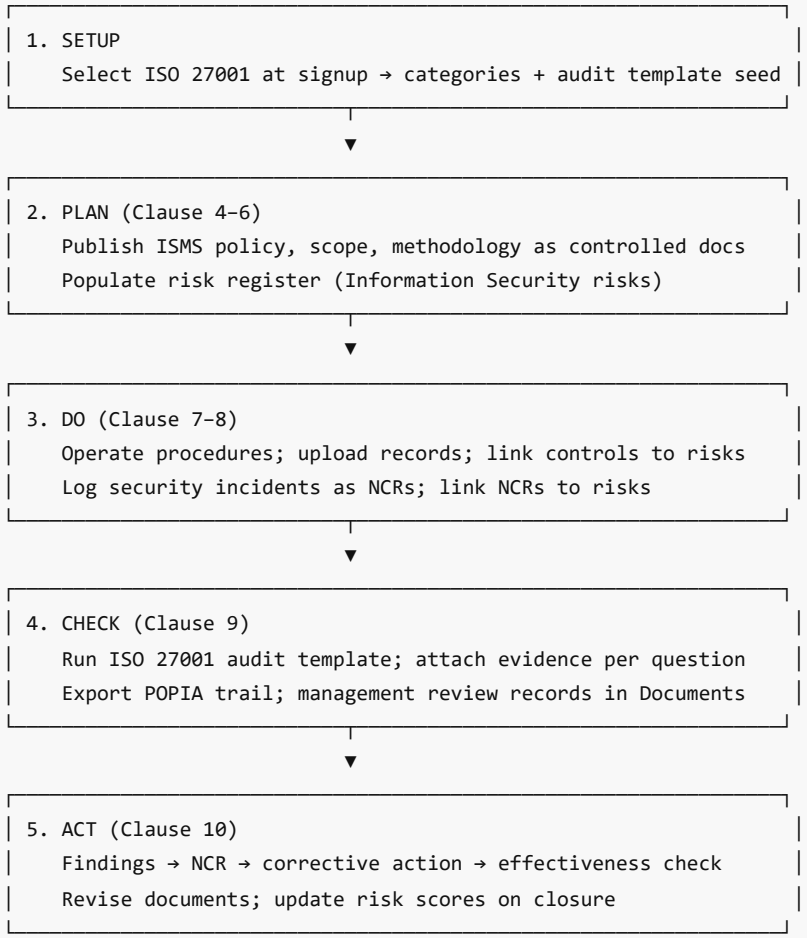
This combination supports **ISO 27001 Clause 7.5** (documented information) and **Annex A 5.24–5.28** (incident and privacy-related planning) from a **records and process** perspective.

### 3.6 Typical ISO 27001 artefacts managed in Maemo

| Artefact | Maemo module | Notes |
|---|---|---|
| Information Security Policy | Documents | Approved, versioned, review-dated |
| ISMS scope statement | Documents | Active controlled document |
| Risk assessment methodology | Documents | Procedure category |
| Risk register | Risks | Information Security category; inherent/residual scores |
| Statement of Applicability | Documents | Manual document or spreadsheet uploaded; SOA builder planned |
| Acceptable use policy | Documents | Standard procedure |

| | | |
|---|---|---|
| Incident response procedure | Documents | Link incidents (NCR) to procedure |
| Security incident records | NCR | Severity, root cause, corrective action |
| Internal audit programme | Audits / API | Audit templates and runs; programme API available |
| Internal audit reports | Audits | Findings with evidence attachments |
| Management review minutes | Documents | Record category |
| Corrective action records | NCR | Full CAPA lifecycle |
| Evidence for certification audit | Documents + Audits | AGSA-style evidence register template |

### 3.7 ISO 27001 implementation workflow on Maemo




### 3.8 ISO 27001 — known gaps and mitigations

| Gap | Impact | Mitigation |
|---|---|---|

| | | |
|---|---|---|
| No Statement of Applicability (SOA) builder | Manual SOA maintenance | Maintain SOA as controlled spreadsheet/document; map controls in audit template questions |
| No Annex A control library | No per-control status dashboard | Use audit template categories aligned to Annex A themes; external GRC tool if required |
| No KRI/KPI module | Limited automated performance monitoring | Track KPIs in management review records; integrate BI tools via Engine API |
| No vulnerability/asset CMDB | Technical control evidence external | Link risk register entries to asset references in text; store scan reports as documents |
| Generic audit template (7 questions) | Not clause-by-clause for all 93 controls | Expand template with consultant-defined questions per Annex A control subset |

---

## 4. ISO 22301:2019 — How Maemo helps

### 4.1 What ISO 22301 requires (brief)

ISO 22301 specifies requirements for a **Business Continuity Management System (BCMS)** to protect against, reduce the likelihood of, prepare for, respond to, and recover from disruptive incidents.

| Clause | Theme |
|---|---|
| 4 | Context of the organisation |
| 5 | Leadership |
| 6 | Planning |
| 7 | Support |
| 8 | Operation (BIA, BC strategies, plans, exercise) |
| 9 | Performance evaluation |
| 10 | Improvement |

### 4.2 Honest assessment: ISO 22301 in Maemo today

**Maemo does not currently include:**

- A dedicated **ISO 22301 module** or template pack
- **Business Impact Analysis (BIA)** tool with recovery time objectives (RTO) / recovery point objectives (RPO)
- **Business continuity strategy** register
- **Exercise and test scheduler** with automated reminders
- **Crisis communication** contact cascade
- **Maximum tolerable period of disruption (MTPD)** tracking

**Maemo does support** the **management system backbone** that BCMS certification still requires:

| BCMS need | Maemo support | Status |
|---|---|---|

| | | |
|---|---|---|
| BC policy | Documents — controlled approval | **Supported** |
| BC scope | Documents | **Supported** |
| BC plans and procedures | Documents — versioned, review-dated | **Supported** |
| Risk of disruption | Risks — Operational / Compliance categories | **Supported** |
| Corrective action after incidents/exercises | NCR — CAPA with effectiveness check | **Supported** |
| Internal audit of BCMS | Audits — custom template (consultant-defined) | **Supported** |
| Management review | Documents — management review template (ISO 9001 pack, adaptable) | **Partially supported** |
| Records retention | Records retention + NARSA metadata | **Supported** |
| Evidence for certification | Documents + Audits | **Supported** |

### 4.3 Clause-by-clause support matrix (ISO 22301:2019)

| Clause | Requirement (summary) | Maemo support | Notes |
|---|---|---|---|
| **4.1** | Context | **Partially supported** | Context analysis as controlled document |
| **4.2** | Interested parties | **Partially supported** | Documented in BCMS records |
| **4.3** | BCMS scope | **Supported** | Scope as approved document |
| **4.4** | BCMS | **Partially supported** | Process records in Maemo; BCMS design is organisational |
| **5.1** | Leadership | **Partially supported** | BC policy with approval evidence |
| **5.2** | Policy | **Supported** | Policy document with workflow |
| **5.3** | Roles | **Partially supported** | Document owners, NCR owners, audit roles |
| **6.1** | Actions for risks/opportunities | **Supported** | Risk register |
| **6.2** | BC objectives | **Partially supported** | Documented objectives; no KPI module |
| **6.3** | Planning changes | **Partially supported** | Change-controlled documents |
| **7.1–7.4** | Support | **Partially supported** | Same as ISO 27001 — documents, templates |
| **7.5** | Documented information | **Supported** | Full document control |

| | | | |
|---|---|---|---|
| **8.2** | Business impact analysis | **Not supported** | Use spreadsheet or dedicated BCM tool; store BIA report as document |
| **8.3** | BC strategies | **Partially supported** | Strategy documents controlled in Maemo |
| **8.4** | BC plans | **Supported** | Plans as controlled documents with review cycle |
| **8.5** | Exercise programme | **Not supported** | Schedule exercises externally; record results as NCR/documents |
| **8.6** | Evaluation of BC documentation | **Partially supported** | Document review workflow; audit module |
| **9.1** | Monitoring | **Partially supported** | Dashboard; review dates |
| **9.2** | Internal audit | **Supported** | Custom BCMS audit template |
| **9.3** | Management review | **Partially supported** | Management review records |
| **10.1** | Nonconformity | **Supported** | NCR module |
| **10.2** | Continual improvement | **Supported** | CAPA loop + document updates |

### 4.4 Running ISO 22301 on Maemo — recommended approach

Until a dedicated BCM module is available, organisations can implement a **document-centric BCMS** on Maemo:

#### Step 1 — Establish BCMS documentation structure

Create document categories (via tenant settings) such as:

- BC Policy
- BC Plan
- BC Procedure
- BIA Report
- Exercise Report
- BC Record

Use the **Control of Documents** and **Control of Records** procedure templates (ISO 9001 pack) as the document control backbone — ISO 22301 Clause 7.5 aligns with the same documented information principles.

#### Step 2 — Business Impact Analysis

Conduct BIA using your preferred method (spreadsheet, workshop output, or specialist BCM software). **Upload the approved BIA report** as a controlled document with:

- Review date (annual or on organisational change)
- Approver sign-off via workflow
- Version history when BIA is updated

#### Step 3 — BC plans and procedures

Maintain **Business Continuity Plans** as active controlled documents:

- Activation criteria
- Recovery teams and contacts (in document content)
- Communication procedures
- Recovery steps per critical activity

Maemo ensures the **correct version** is active, review is not overdue, and obsolete plans are archived.

#### Step 4 — Risks of disruption

Register disruption-related risks in the **Risks module**:

- Category: **Operational** or **Compliance**
- Inherent/residual assessment of disruption likelihood and impact
- Link to BC plans (reference in risk description or related document title)
- Link to NCRs when incidents occur

#### Step 5 — Exercises and tests

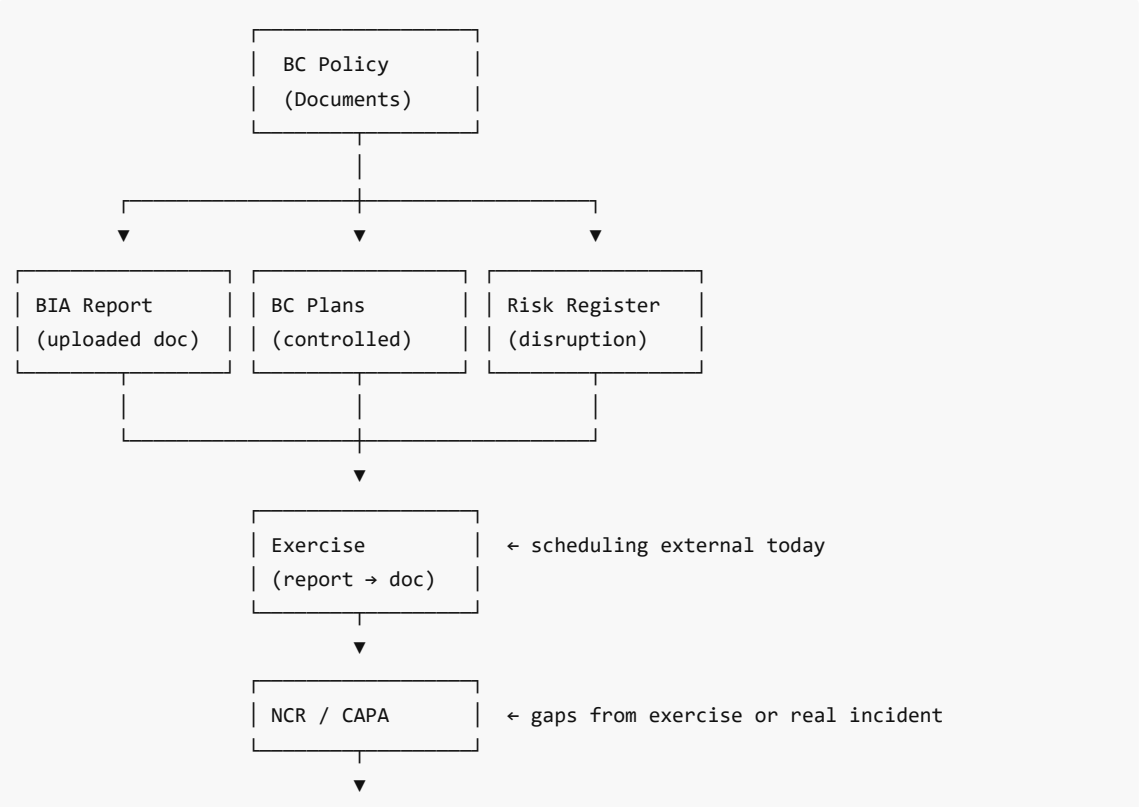
When exercises are conducted:

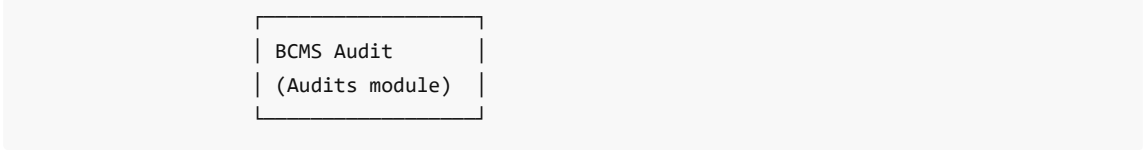
1. Record exercise **results** as a controlled document (Exercise Report)
2. Raise **NCRs** for gaps found during the exercise
3. Link NCRs to relevant **risks** and **audit findings** if an internal BCMS audit is running in parallel
4. Track corrective actions to closure with effectiveness confirmation

#### Step 6 — Internal audit and certification

Create a **BCMS audit template** (consultant or internal auditor) with questions mapped to ISO 22301 clauses. Execute audit runs, attach evidence, raise findings as NCRs.

### 4.5 ISO 22301 workflow diagram (current capabilities)






### 4.6 ISO 22301 — roadmap

Codist plans the following BCM enhancements (indicative; not committed dates):

| Planned capability | Benefit for ISO 22301 |
|---|---|
| ISO 22301 template pack | BC policy, BIA procedure, exercise procedure, plan templates |
| BIA register | Activities, MTPD, RTO, RPO, dependencies |
| Exercise programme | Schedule, reminders, link to NCR on failure |
| BC plan activation log | Record activations as NCR or dedicated record type |
| Combined ISMS + BCMS dashboard | Unified view for organisations running both standards |

Contact Codist for roadmap timing if ISO 22301 certification is on a fixed deadline.

---

## 5. Combined ISO 27001 + ISO 22301 on one Maemo tenant

Many organisations implement **information security** and **business continuity** together. Maemo supports a unified approach:

| Shared capability | ISO 27001 use | ISO 22301 use |
|---|---|---|
| Document control | ISMS policies, procedures, SOA | BC plans, BIA reports, exercise records |
| Risk register | Information security risks | Operational disruption risks |
| NCR / CAPA | Security incidents, control failures | Exercise gaps, real disruption events |
| Audits | ISMS internal audit (seeded template) | BCMS internal audit (custom template) |
| POPIA trail | Personal data access evidence | Privacy during crisis (if PII in BC contacts) |
| Records retention | Security logs retention policy docs | BC records retention |

### Suggested document taxonomy (combined tenant)

| Category | ISO 27001 examples | ISO 22301 examples |
|---|---|---|
| Information Security Policy | Acceptable use, access control policy | — |
| Information Security Procedure | Incident response, backup procedure | — |
| BC Policy | — | Business continuity policy |
| BC Plan | IT disaster recovery plan (also ISO 27001 A.5.29) | Organisational BC plan |

| | | |
|---|---|---|
| Shared records | Incident logs, audit reports | Exercise reports, activation records |

---

## 6. Audit and certification preparation checklist

Use this checklist when preparing for an ISO 27001 or ISO 22301 certification audit with Maemo as your compliance platform.

### 6.1 Before the certification audit

- ☐ All policies and procedures are **Active** with current review dates
- ☐ Risk register is populated with **Information Security** (27001) and/or **Operational** (22301) risks
- ☐ Residual scores reflect implemented controls
- ☐ Open NCRs have owners, due dates, and corrective actions
- ☐ Internal audit completed within the certification cycle; findings closed or with approved action plans
- ☐ Management review records uploaded for the review period
- ☐ POPIA access trail exported (if applicable)
- ☐ Consultant/auditor has access to run audit templates or export evidence

### 6.2 Evidence commonly requested by auditors

| Auditor request | Where in Maemo |
|---|---|
| Show me your approved Information Security Policy | Documents → Active → category Information Security Policy |
| Show version history of the BC plan | Documents → version history |
| Show risk assessment for [system/process] | Risks → filter Information Security or Operational |
| Show corrective action from last incident | NCR → linked to risk/audit finding |
| Show internal audit programme | Audit templates/runs (programme API if using integrated scheduling) |
| Show evidence of document review | Document review dates; workflow approval timestamps |
| Show who accessed personal information records | Admin → POPIA trail report |

---

## 7. Comparison summary

| Dimension | ISO 27001 on Maemo | ISO 22301 on Maemo |
|---|---|---|
| **Onboarding seed** | Yes — categories + audit template | No — manual setup today |
| **Document control** | Fully supported | Fully supported |
| **Risk register** | Information Security category | Operational / Compliance categories |

| | | |
|---|---|---|
| **CAPA / incidents** | NCR module | NCR module |
| **Internal audit** | Pre-seeded ISO 27001 template | Custom template required |
| **POPIA alignment** | Strong | Adjacent (contact data in plans) |
| **BIA / RTO / RPO** | Not in scope (cyber BIA as document) | Not supported — external tool |
| **Exercise management** | Not supported | Not supported |
| **Certification readiness** | **High** with complementary IT controls | **Moderate** — BCMS ops tooling needed for Clause 8.2/8.5 |

---

## 8. Professional services from Codist

Codist can assist with ISO 27001 and ISO 22301 implementations on Maemo:

| Service | Description |
|---|---|
| ISMS quick-start | ISO 27001 template customisation, risk register seed, audit template expansion |
| BCMS document-centric setup | Category structure, plan templates, exercise-to-NCR workflow design |
| POPIA + ISO 27001 alignment | PII classification scheme, retention rules, trail reporting setup |
| Consultant enablement | Multi-tenant consultant configuration, client audit templates |
| Migration | Import existing policies, risks, and registers from Excel |
| Pre-certification review | Gap analysis against ISO 27001/22301 using Maemo artefact review |

Contact: **technical@codist.co.za** | https://maemo-compliance.co.za/contact

---

## 9. Glossary

| Term | Definition |
|---|---|
| BIA | Business Impact Analysis |
| BCMS | Business Continuity Management System |
| CAPA | Corrective and Preventive Action |
| ISMS | Information Security Management System |
| MTPD | Maximum Tolerable Period of Disruption |
| NCR | Non-Conformance Report |
| PDCA | Plan-Do-Check-Act |

| | |
|---|---|
| POPIA | Protection of Personal Information Act (South Africa) |
| RPO | Recovery Point Objective |
| RTO | Recovery Time Objective |
| SOA | Statement of Applicability (ISO 27001) |

---

## 10. Disclaimer

This guide describes how Maemo Compliance **supports** ISO/IEC 27001:2022 and ISO 22301:2019 implementation. It is not a substitute for the official standard texts, legal advice, or certification body requirements. Control mappings are indicative; your organisation is responsible for determining applicability of requirements and demonstrating conformity to your auditor.

Features described as planned are not contractual unless agreed in writing. Standards versions cited: ISO/IEC 27001:2022, ISO 22301:2019.

---

**Codist (Pty) Ltd**
Product: Maemo Compliance
Web: https://maemo-compliance.co.za
Email: technical@codist.co.za

*End of document*